

Cybersecurity Internship – Week 1 Report

Security Assessment of User Management Web Application

Intern Name:

Muhammad Talha

Week:

Week 1 – Security Assessment

Project Title:

User Management System – Vulnerability Analysis

1. Project Overview

This project is a simple **User Management Web Application** built using Node.js, Express, and MongoDB. The system includes features such as user registration, login, and profile management with JWT-based authentication.

The objective of Week 1 was to analyze the application, understand its functionality, and perform basic security testing to identify potential vulnerabilities.

2. Environment Setup

The following setup was used:

- Node.js backend application
- Express.js framework
- MongoDB Atlas database
- Postman for API testing
- Browser Developer Tools for input testing

Application Start:

- Server running on: `http://localhost:3000`
- MongoDB successfully connected

3. APIs Tested

The following endpoints were tested:

✓ User Registration

POST /api/v1/users/register

✓ User Login

POST /api/v1/users/login

✓ Protected Route (Account Details)

GET /api/v1/users/account

All APIs were tested using Postman and responded successfully.

4. Security Testing Performed

4.1 Cross-Site Scripting (XSS) Test

◆ Test Input:

```
<script>alert('XSS')</script>
```

◆ Result:

The input was successfully stored in the database but was not executed in the API response.

◆ Observation:

The application does not sanitize user inputs, which may lead to Stored XSS vulnerability if the data is rendered in a frontend without proper escaping.

4.2 SQL Injection Test

◆ Test Input:

```
admin' OR '1'='1
```

◆ Result:

The system returned:

Wrong credentials

◆ Observation:

The application is not vulnerable to basic SQL injection attacks as it uses MongoDB with Mongoose ORM, which prevents direct query manipulation.

4.3 Authentication Test

- ◆ Observations:
 - JWT token is generated successfully on login
 - Protected routes require valid token
 - Unauthorized access is restricted

5. Key Observations

- User authentication system is functional
- Passwords are securely hashed using bcrypt
- JWT-based authentication is implemented correctly
- Input validation is partially missing
- No rate limiting mechanism is implemented

6. Identified Security Issues

- Lack of input sanitization (XSS risk)
- No rate limiting (brute force risk)
- No strict input validation on all fields
- Potential exposure if frontend renders unsanitized data

7. Recommendations

- Implement input sanitization (e.g., validator / DOMPurify)
- Add rate limiting middleware (e.g., express-rate-limit)
- Improve password policy enforcement
- Add security headers using Helmet.js
- Implement logging for suspicious activities

8. Conclusion

The application is stable and demonstrates proper backend authentication using JWT and MongoDB. However, some security improvements are required to enhance protection against common vulnerabilities such as XSS and brute force attacks.

Overall, Week 1 objectives have been successfully completed, including:

- ✓ Application setup
- ✓ API testing
- ✓ Security vulnerability assessment
- ✓ Basic penetration testing

END OF REPORT